

LensOverlay Privacy and Security Note

Date: 2026-05-23

Data Flow

- Global build: local-first OCR/translation path. Server translation is disabled by build config.
- China build: server translation can be enabled for OCR text. The app sends OCR line data, not source image/base64 screen frames, to the configured proxy.
- Android APKs do not contain upstream LLM API keys. The server proxy reads upstream keys from server-side environment variables.

Permissions

The release APK declares camera, internet, overlay, foreground service, media projection foreground service, notification, and network-state permissions.

The tested flow makes sensitive permissions explicit:

- Camera starts only after user action.
- Screen translate requires overlay readiness plus Android MediaProjection consent.
- Foreground screen capture shows the Android system recording/casting indicator.
- Screen translate can be stopped from the result sheet and removes the virtual display.

Local Storage Change

Subagent privacy review found a P0 issue in the copied source: camera and screen translation were saving source and translated images automatically under app external files.

Fix applied in the copied working source:

- Release builds no longer auto-save camera source images.
- Release builds no longer auto-save camera translated images.
- Release builds no longer auto-save screen source captures.
- Release builds no longer auto-save screen translated captures.
- Debug builds keep the diagnostic image-saving behavior for QA only.

Evidence:

- Camera capture release UI showed disabled save state when no output image was persisted.
- Screen translate release log showed `sourceImageSaved=false`.
- `/sdcard/Android/data/com.lensoverlay.translate.china/files` was empty after tested release camera and screen capture flows.

Logs and Cache

- App logs use counts, latency, request IDs, and save-state booleans rather than dumping source images.
- Existing debug image test paths remain diagnostic-only and should not be enabled as a user-facing release path.
- Android translation cache is memory based.
- Server cache is in-memory and time-limited in the current proxy implementation.

Server Proxy Risks

Current proxy auth/rate-limit design is acceptable for a portfolio prototype but not enough for enterprise production:

- Proxy shared secret is optional in the current server code.
- Android app does not send a proxy shared secret header.
- In-memory rate limit does not survive serverless cold starts or multi-instance deployment.

Production recommendation:

- Use server-issued short-lived tokens or app attestation, not a static secret embedded in the Android APK.
- Move quota/rate limit state to Redis/KV or an equivalent durable store.
- Add per-user/project quotas, audit logs, and cost guardrails.

Submission Wording

Safe wording:

> The APK keeps upstream AI keys out of the client. Release QA builds do not auto-save source camera or screen-capture images. China flavor may send OCR text, not raw images, to the server proxy when remote translation is enabled.

Avoid saying:

> This is production security complete.

Remaining production work: physical-device validation, production signing, durable abuse controls, privacy notice copy, server auth redesign, and region-network latency evidence.